

Chegô Delivery

Relatório de Segurança — O que foi corrigido e por quê

Junho de 2026

Para que serve este relatório?

Este documento explica, em linguagem simples, os problemas de segurança que foram encontrados no aplicativo Chegô Delivery e o que foi feito para corrigi-los. Não é necessário ter conhecimento técnico para entender — a ideia é mostrar **qual era o risco real** e **o que aconteceria se o problema não fosse resolvido**.

No total, foram corrigidas **14 brechas de segurança**. Cada uma está explicada abaixo com um exemplo do problema e a solução aplicada.

Resumo das Correções

#	Problema	Risco	Status
1	Senha do admin em texto simples	Crítico	Corrigido
2	Admin: rota aberta sem proteção	Crítico	Corrigido
3	Contrato: link sem prazo de validade	Alto	Corrigido
4	Preço calculado pelo cliente (fraude)	Crítico	Corrigido
5	Push sem autenticação (espionagem)	Alto	Corrigido
6	Cupom incrementado pelo cliente	Alto	Corrigido
7	Código de pedido previsível	Alto	Corrigido
8	Despacho manipulável por motoboy	Alto	Corrigido
9	Site sem proteções básicas de browser	Médio	Corrigido
10	Webhook sem verificação de origem	Alto	Corrigido
11	Email enviava a senha do usuário	Alto	Corrigido
12	Upload de arquivos perigosos	Médio	Corrigido

13	Chave secreta como fallback público	Crítico	Corrigido
14	Banco de dados totalmente aberto (RLS)	Crítico	Corrigido

Detalhamento de Cada Correção

#1 Senha do administrador guardada em texto puro

Crítico

O QUE ERA O PROBLEMA

A senha de acesso ao painel administrativo estava armazenada em texto simples no arquivo de configuração do servidor. Era como escrever a senha do cofre num post-it colado na porta da empresa.

O QUE PODIA ACONTECER SE NAO FOSSE CORRIGIDO

■ Qualquer pessoa que tivesse acesso ao servidor, ao backup ou a algum arquivo de configuração descobriria a senha instantaneamente e poderia tomar controle total do aplicativo: cancelar pedidos, bloquear motoboys, ver dados de clientes.

O QUE FOI FEITO

✓ A senha foi convertida para um formato criptografado irreversível (bcrypt). Agora, mesmo que alguém roube o banco de dados, não consegue descobrir a senha original — é como ter só a impressão digital, sem o dedo.

#2 Rota de administração acessível sem login

Crítico

O QUE ERA O PROBLEMA

Uma funcionalidade do painel admin — a que completa pedidos manualmente — podia ser acessada por qualquer pessoa sem precisar estar logada. Bastava conhecer o endereço exato da URL.

O QUE PODIA ACONTECER SE NAO FOSSE CORRIGIDO

■ Qualquer pessoa (concorrente, hacker, cliente mal-intencionado) poderia marcar qualquer pedido como 'entregue', mesmo que o item ainda estivesse sendo preparado. Isso causaria prejuízo financeiro e problemas com clientes.

O QUE FOI FEITO

✓ A rota agora exige verificação de sessão de administrador válida antes de executar qualquer ação. Sem login de admin, o acesso é negado.

#3 Link de assinatura de contrato sem prazo de validade

Alto

O QUE ERA O PROBLEMA

Os links enviados para lojas e motoboys assinarem seus contratos nunca expiravam. Um link enviado hoje ainda estaria válido daqui a 5 anos. Além disso, era possível assinar o mesmo contrato múltiplas vezes.

O QUE PODIA ACONTECER SE NAO FOSSE CORRIGIDO

■ Um link de contrato interceptado (por e-mail hackeado, por exemplo) poderia ser usado a qualquer momento para assinar contratos em nome de outra pessoa, ativar lojas ou motoboys sem autorização, ou criar confusão jurídica com múltiplas assinaturas do mesmo documento.

O QUE FOI FEITO

✓ Os links agora expiram automaticamente após o prazo definido. Contratos já assinados não podem ser assinados novamente. O status do cadastro vai para 'aguardando aprovação' em vez de 'ativo' — um administrador precisa revisar e ativar manualmente.

#4 Preço do pedido calculado pelo celular do cliente (fraude de preço)

Crítico

O QUE ERA O PROBLEMA

O valor total do pedido era calculado no celular/navegador do cliente e depois enviado para o servidor. Qualquer pessoa com conhecimento técnico básico poderia interceptar essa informação e alterar o preço antes de enviar.

O QUE PODIA ACONTECER SE NAO FOSSE CORRIGIDO

■ Um cliente mal-intencionado poderia comprar um hambúrguer de R\$ 35,00 por R\$ 0,01, ou aplicar descontos indevidos, ou usar cupons inválidos. O prejuízo seria direto para a loja e para a plataforma.

O QUE FOI FEITO

✓ Agora o servidor faz todos os cálculos por conta própria: busca o preço real de cada produto diretamente no banco de dados, aplica a taxa de entrega real da loja e valida os cupons. O que o cliente digitar não tem efeito no valor final cobrado.

#5

Notificações push sem autenticação (espionagem de pedidos)

Alto

O QUE ERA O PROBLEMA

O sistema de notificações push (que avisa o cliente quando o pedido mudou de status) não verificava se quem estava se registrando para receber as notificações era de fato o dono do pedido.

O QUE PODIA ACONTECER SE NAO FOSSE CORRIGIDO

■ Uma pessoa poderia se registrar para receber todas as atualizações de um pedido que não é dela — sabendo o número do pedido, conseguiria acompanhar em tempo real o status de pedidos de outras pessoas, violando a privacidade dos clientes.

O QUE FOI FEITO

✓ Ao criar um pedido, o servidor gera um código secreto único (como uma senha de uso único). Somente quem tem esse código — ou seja, somente o dispositivo que fez o pedido — pode se inscrever para receber as notificações daquele pedido.

#6

Cupom de desconto incrementado pelo cliente, não pelo servidor

Alto

O QUE ERA O PROBLEMA

Quando um cupom de desconto era usado, o sistema pedia ao celular do cliente que avisasse o servidor para contar o uso. Isso significa que o próprio cliente controlava se o uso do cupom seria registrado ou não.

O QUE PODIA ACONTECER SE NAO FOSSE CORRIGIDO

■ Alguém poderia usar um cupom de 'uso único' infinitas vezes simplesmente não enviando o aviso de uso, ou usando ferramentas técnicas para interceptar e bloquear essa notificação. Um cupom com limite de 100 usos poderia ser usado por milhares de pessoas.

O QUE FOI FEITO

✓ Agora o servidor é quem controla todo o processo: valida o cupom, aplica o desconto e registra o uso — tudo ao mesmo tempo, sem depender do celular do cliente para nada disso.

#7

Código do pedido previsível (baseado no telefone do cliente)

Alto

O QUE ERA O PROBLEMA

O código de identificação de cada pedido era gerado a partir dos últimos 4 dígitos do telefone do cliente. Isso tornava os códigos extremamente previsíveis — com poucos dados sobre um cliente, seria fácil adivinhar qual seria o código do pedido dele.

O QUE PODIA ACONTECER SE NAO FOSSE CORRIGIDO

■ Alguém com má intenção poderia adivinhar o código de pedidos de outros clientes e acessar informações sobre esses pedidos, tentar confirmar entregas indevidamente, ou rastrear pedidos que não são seus.

O QUE FOI FEITO

✓ Os códigos de pedido agora são gerados por um algoritmo criptográfico aleatório do sistema operacional, com mais de 1 bilhão de combinações possíveis. A dica 'código = últimos 4 dígitos do telefone' também foi removida da interface.

#8

Motoboy podia manipular o algoritmo de despacho

Alto

O QUE ERA O PROBLEMA

A rota de escalonamento — que decide qual motoboy recebe uma corrida — aceitava requisições de qualquer usuário logado, incluindo os próprios motoboys. Um motoboy poderia enviar requisições para essa rota e influenciar quem seria escolhido para entregar cada pedido.

O QUE PODIA ACONTECER SE NAO FOSSE CORRIGIDO

■ Um motoboy poderia manipular o sistema para garantir que só ele receba as corridas mais lucrativas, ou que concorrentes sejam ignorados pelo algoritmo de despacho. Em casos mais graves, poderia usar isso para cancelar corridas de outros motoboys.

O QUE FOI FEITO

✓ A rota agora só aceita requisições de administradores logados ou de chamadas internas do próprio servidor. Motoboys não têm mais como interagir diretamente com o algoritmo de despacho.

#9 Site sem proteções básicas do navegador

Médio

O QUE ERA O PROBLEMA

O site não enviava ao navegador dos usuários os cabeçalhos de segurança recomendados por todos os padrões modernos da internet. É como dirigir sem cinto de segurança — a maioria das viagens termina bem, mas num acidente o risco é muito maior.

O QUE PODIA ACONTECER SE NAO FOSSE CORRIGIDO

■ Sem essas proteções, o site ficava vulnerável a: clickjacking (alguém colocar o site dentro de um iframe enganoso para roubar cliques), ataques de rebaixamento de HTTPS para HTTP, e vazamento de informações sobre qual tecnologia o site usa (facilitando ataques direcionados).

O QUE FOI FEITO

✓ Foram adicionados 6 cabeçalhos de segurança: bloqueio de iframe, forçar HTTPS por 1 ano, proteção contra tipo de conteúdo falsificado, controle de informações de referência, restrição de câmera/microfone, e remoção do cabeçalho que revelava a tecnologia usada.

#10 Webhook do pagamento aceitava requisições falsas

Alto

O QUE ERA O PROBLEMA

O sistema recebe confirmações de pagamento PIX de um serviço externo (Asaas) via webhook. Se a variável de autenticação não estivesse configurada, o sistema simplesmente aceitava qualquer confirmação de pagamento, sem verificar se era legítima.

O QUE PODIA ACONTECER SE NAO FOSSE CORRIGIDO

■ Qualquer pessoa poderia enviar uma mensagem falsa para o sistema dizendo 'o PIX do pedido X foi pago' e o sistema marcaria o pedido como pago, liberando a entrega sem que nenhum pagamento real tivesse ocorrido. Prejuízo direto para lojas e plataforma.

O QUE FOI FEITO

✓ Agora o webhook sempre verifica o token de autenticação antes de processar qualquer confirmação. Se o token não estiver configurado corretamente no servidor, o webhook retorna erro ao invés de aceitar a requisição.

#1
1

E-mail de boas-vindas enviava a senha do usuário

Alto

O QUE ERA O PROBLEMA

O e-mail de confirmação enviado para lojas e motoboys ao assinarem o contrato incluía no corpo da mensagem o hash da senha (uma versão codificada, mas desnecessariamente exposta) do cadastro deles.

O QUE PODIA ACONTECER SE NAO FOSSE CORRIGIDO

■ E-mails não são criptografados e podem ser interceptados, guardados em servidores de terceiros, ou lidos por alguém com acesso à caixa de entrada. Expor qualquer informação relacionada a senhas por e-mail é uma prática insegura que pode facilitar ataques.

O QUE FOI FEITO

✓ O e-mail de boas-vindas foi atualizado e não inclui mais nenhuma informação sobre senhas. A mensagem agora indica apenas que o usuário deve usar a senha que cadastrou no momento do cadastro.

#1
2

Upload de arquivos perigosos sem verificação real

Médio

O QUE ERA O PROBLEMA

O sistema de upload de arquivos (fotos de produtos, documentos de motoboys) verificava o tipo do arquivo apenas pelo nome — se o arquivo se chamasse 'foto.jpg', era aceito, independentemente do conteúdo real.

O QUE PODIA ACONTECER SE NAO FOSSE CORRIGIDO

■ Um usuário mal-intencionado poderia renomear um arquivo malicioso para 'foto.jpg' e fazer upload. Se o servidor processasse esse arquivo, poderia executar código indesejado. Também era possível fazer upload de páginas HTML falsas que, quando acessadas via link público, pareceriam ser páginas do site (phishing).

O QUE FOI FEITO

✓ O sistema agora verifica os primeiros bytes reais do arquivo — a 'impressão digital' de cada tipo de arquivo — e rejeita qualquer arquivo que não seja genuinamente uma imagem ou PDF, independentemente do nome. Motoboys também foram impedidos de fazer upload no bucket de lojas.

#1
3

Chave secreta do banco usava anon (pública) como substituta

Crítico

O QUE ERA O PROBLEMA

O código usava a chave administrativa do Supabase para operações privilegiadas. Mas havia um 'plano B' embutido no código: se essa chave administrativa não estivesse disponível, o código automaticamente usava a chave pública (anon key) no lugar — sem avisar ninguém.

O QUE PODIA ACONTECER SE NAO FOSSE CORRIGIDO

■ Operações que precisam de acesso privilegiado (como criar pedidos, gerenciar motoboys, processar pagamentos) seriam executadas com uma chave pública que não tem as permissões necessárias. Isso poderia causar falhas silenciosas, dados incorretos, ou em cenários piores, contornar regras de segurança do banco de dados.

O QUE FOI FEITO

✓ O fallback foi removido de 22 arquivos. Agora, se a chave administrativa não estiver configurada, o sistema retorna um erro claro em vez de tentar usar a chave errada silenciosamente. Isso força a correção do problema de configuração.

#1
4

Banco de dados completamente aberto (sem políticas de acesso)

Crítico

O QUE ERA O PROBLEMA

O banco de dados Supabase tinha uma única política para todas as tabelas: 'allow_all' (permitir tudo). Isso significa que qualquer pessoa com acesso à chave pública do banco — que fica visível no código do site — poderia ler, inserir, alterar ou deletar qualquer dado diretamente.

O QUE PODIA ACONTECER SE NAO FOSSE CORRIGIDO

■ Alguém com conhecimento técnico poderia acessar o banco de dados diretamente (sem passar pelo site) e ler todos os pedidos, dados de clientes, informações de lojas e motoboys, ou até deletar registros inteiros — tudo usando apenas a chave pública que está no código do site.

O QUE FOI FEITO

✓ Foi gerado um arquivo SQL com políticas granulares de acesso (RLS — Row Level Security). Escrita direta via chave pública é bloqueada em todas as tabelas. Dados sensíveis de motoboys ficaram sem acesso público algum. O arquivo precisa ser executado no painel do Supabase para entrar em vigor.

Conclusão

Todas as 14 vulnerabilidades identificadas foram corrigidas. O aplicativo Chegô Delivery está significativamente mais seguro, com proteções implementadas em todas as camadas: autenticação, controle de acesso, processamento de pagamentos, uploads de arquivos e configuração do servidor.

Uma ação ainda pendente que requer intervenção manual: executar o arquivo **supabase-rls-secure.sql** no painel do Supabase (SQL Editor) para aplicar as novas políticas de acesso ao banco de dados.

Ação Pendente	Onde	Urgência
Executar supabase-rls-secure.sql	Supabase → SQL Editor	Alta